

AgentsGate

Rules & Policy — Beginner's Guide

English edition — the Japanese edition is [agentsgate-rules-guide_jp.pdf](#)

Version 1.1 · 2026-07-29

AgentsGate Rules & Policy Guide

Protection levels

Database reads: counting and table names

A SELECT that names a table or column that sounds sensitive — users, passwords, tokens, credentials, billing — scores 0.60 and waits for approval at the strict level. Two things about that are easy to trip over.

Counting is exempt. SELECT count(*) FROM users returns one number and no column values, so it scores 0.05 like any other read. Only count() is exempt: max(password) is the largest password verbatim, group_concat(email) returns every row in one string, and sum(balance) WHERE id = 42 is one person's balance.

Singular and plural both count. user, users, public."User", app_user and user_accounts all match. A column named user_id does not — the singular form is only recognised in table position, after FROM or JOIN.

A score alone cannot say what should happen. DROP TABLE scores 1.00 and SELECT * FROM users scores 0.60 — they differ in kind, not degree, so moving the threshold until the SELECT passes also clears DELETE FROM orders at 0.90. Every built-in rule therefore carries a category, and the protection level says what to do with each.

agentsgate level — show what is stopped right now, and why

agentsgate level strict — change it. The dashboard has the same switch in its header, and changing it there applies to the running proxy immediately.

minimal — only wholesale destruction is stopped: DROP, TRUNCATE, a DELETE with no WHERE. For a scratch project.

balanced — the default. Adds credential files (.env, .pem) and outbound deletions. Writing code, running tests and editing rows all run without a prompt.

strict — adds personal-data reads, outbound sends, shell commands and deletions to what needs a human. For data that is not only yours.

balanced is a convenience posture, not a data-protection one: shell commands run and a table called users can be read. Policy rules are applied after the level and override it.

This guide explains how to customize AgentsGate's policy rules — the controls that decide which AI agent operations are allowed, blocked, or paused for your review. No programming knowledge required.

1. How Rules Work

Every time your AI agent makes a tool call (reading a file, sending an email, querying a database, etc.), AgentsGate evaluates it against two layers of rules:

- **Built-in L1 Rules** — hardcoded safety rules that always run. You cannot delete them, but you can mute or tune them.
- **Custom Policy Rules** — rules you create to fit your specific needs. These run after L1 and can override the score or force a specific action.

Each rule either:

- **Sets a risk score** (0.0 = safe → 1.0 = dangerous) — the highest score from all matching rules determines the final outcome
- **Forces an action** — block, allow, or require_approval, bypassing the threshold calculation



Think of L1 rules as a factory alarm system. Your custom rules are the access badges and override keys you hand out to specific people or teams.

2. The Rules Tab in the Dashboard

Open the dashboard (<http://localhost:4001>) and click the Rules tab. You will see three sections:

Policy Rules table

Lists all your custom rules with a Hits column showing how many times each rule has matched a real operation since the proxy started. Rules with 0 hits (shown in faint text) may be dead weight.

Column	What it shows
Priority	Evaluation order — lower number = checked first
ID	Unique identifier for the rule
Description	Your human-readable label
Tool	Which MCP tool the rule targets
Method	Which method the rule targets
Action	block / allow / require_approval
Score	Custom risk score override (if set)
Hits	How many real operations matched this rule
Actions	Edit or Delete buttons

Built-in L1 Rules section

Displays all hardcoded L1 rules — their IDs, default scores, and what triggers them. These cannot be deleted from the dashboard, but you can mute or tune them via the policy file.

Preset Templates

Six one-click buttons to create the most common protection rules without writing JSON:

Preset	What it creates
Block filesystem deletes	Blocks delete / remove / unlink / rmdir on the filesystem tool
Require Approval: Email	Approval gate for send / reply / forward on Gmail
Require Approval: Slack	Approval gate for Slack messages to public channels
Read-Only Agent	Blocks write / delete / create / update on a named agent — edit the agentId after adding
Trust Internal Email	Auto-allows email ops to your company domain
Block calendar deletions	Blocks delete / remove / cancel on Google Calendar

Clicking a preset opens the rule editor pre-filled. Review the details, adjust if needed, then click Save.

3. Quick-Create Rules from Operation Rows

The fastest way to protect against a suspicious operation is to turn it directly into a rule without leaving the Operations tab.

How to use it

- Go to the Operations tab
- Click any row to expand its detail panel
- Scroll to the Quick rule: bar at the bottom of the detail panel
- **Block tool/method** — creates a rule that blocks this exact combination
 - **Require approval** — creates a rule that pauses this operation for your review
 - **Trust agent agentId** — creates an allow rule that always trusts this specific agent

- Each button opens the rule editor pre-filled — adjust and click Save

Step-by-step example: blocking unexpected Slack messages

- You notice an operation: slack → send_message, which you did not expect your agent to perform
- Click the operation row to expand it
- Click Block slack/send_message in the Quick rule: bar
- The rule editor opens with: `ID: BLOCK_SLACK_SEND_MESSAGE` `action: block` `tool: slack`
`method: send_message`
- Click Save — the rule is immediately active
- Future slack/send_message calls are blocked and logged

💡 Quick-create buttons are also available for the Block and Approve presets. Use them as starting points, then fine-tune with paramsMatch to narrow the rule to only the specific channel or recipient.

4. Creating and Editing Rules Manually

Click New Rule in the Rules tab to open the rule editor. You can also edit policy.json directly — the file is at:

```
~/.agentsgate/policy.json          (macOS / Linux)
C:\Users\<name>\.agentsgate\policy.json (Windows)
```

Rule structure

```
{
  "id": "MY_RULE_ID",
  "description": "Human-readable label",
  "match": {
    "tool": "slack",
    "method": "send_message"
  },
  "action": "block",
  "priority": 10
}
```

Field	Required?	Description
id	Yes	Unique identifier. Appears in logs and the Hits table.
description	No	Free-text label shown in the dashboard.
match	Yes	Conditions that must all match (AND logic). See Section 5.
action	No	block, allow, or require_approval. Overrides thresholds.
score	No	Risk score override (0.0–1.0). Used when no action is set.
priority	No	Evaluation order. Default: 100. Lower = evaluated first.
redact	No	List of param keys to replace with [REDACTED] in logs.
max	No	Cap on the score this rule can contribute.

5. Match Criteria — Targeting the Right Operations

Every field inside `"match"` must match for the rule to fire (AND logic). You can use exact strings or `/regex/flags` patterns.

Match field	What it targets	Example value
tool	MCP tool name	"slack" or "/gmail outlook/"
method	Tool method name	"send_message" or "/delete remove/i"
agentId	Agent identifier	"my-agent" or "/^prod-.*/"
pathPattern	params.path or params.filePath	"/secrets/" or "/\.env\$/"
tags	Operation tags (all must match)	["production", "sensitive"]
paramsMatch	Any field inside operation params	{ "channel": "/^D[A-Z0-9]+/" }

5a. Simple exact match

Match any call to the slack tool's send_message method:

```
"match": { "tool": "slack", "method": "send_message" }
```

5b. Regex match

Match any delete or remove method on any tool (case-insensitive):

```
"match": { "method": "/delete|remove/i" }
```

5c. Match by agent

Match all operations from agents whose ID starts with "prod-":

```
"match": { "agentId": "/^prod-/" }
```

5d. Match by file path (paramsMatch)

Use `paramsMatch` to inspect individual fields inside the operation's params object. This is how you distinguish a Slack DM from a channel message, or an internal email from an external one.

Match only Slack direct messages (DM channel IDs start with "D"):

```
"match": {
  "tool": "slack",
  "method": "send_message",
  "paramsMatch": { "channel": "/^D[A-Z0-9]+/" }
}
```

6. Full Example Rules

Example A — Block all Slack messages

Goal: Prevent the AI agent from ever sending Slack messages without your explicit approval.

```
{
  "id": "BLOCK_ALL_SLACK_SEND",
  "description": "Block agent from sending any Slack message",
  "match": { "tool": "slack", "method": "/send|post|reply/i" },
  "action": "block",
  "priority": 5
}
```

Example B — Require approval for Slack DMs only

Goal: Allow the agent to post to public channels freely, but require your approval for direct messages.

```
{
  "id": "APPROVE_SLACK_DM",
  "description": "Require approval for Slack direct messages",
```

```

"match": {
  "tool": "slack",
  "method": "send_message",
  "paramsMatch": { "channel": "/^D[A-Z0-9]+/" }
},
"action": "require_approval",
"priority": 5
}

```

Example C — Block external email recipients

Goal: Prevent the agent from emailing anyone outside your company domain.

```

{
  "id": "BLOCK_EXTERNAL_EMAIL",
  "description": "Block outbound email to non-company addresses",
  "match": {
    "tool": "gmail",
    "method": "/send|reply|forward/i",
    "paramsMatch": {
      "to": "/^(?!.*@mycompany\\.com).*$/ "
    }
  },
  "action": "block",
  "priority": 5
}

```

Example D — Block deletes on the production calendar

Goal: Protect a specific Google Calendar from deletion.

```

{
  "id": "BLOCK_PROD_CALENDAR_DELETE",
  "description": "Block event deletions on the production calendar",
  "match": {
    "tool": "google-calendar",
    "method": "delete_event",
    "paramsMatch": { "calendarId": "production@mycompany.com" }
  },
  "action": "block",
  "priority": 5
}

```

Example E — Trust a read-only agent

Goal: Give a reporting agent a low risk score so it never triggers approval prompts.

```

{
  "id": "TRUST_READONLY_AGENT",
  "description": "Always allow the reporting agent",
  "match": { "agentId": "reporting-agent" },
  "score": 0.05,
  "priority": 1
}

```

Example F — Elevate risk for writes to sensitive paths

Goal: Any write to a path containing /secrets/ or /.env should trigger an approval regardless of the default threshold.

```

{

```

```

    "id": "ELEVATE_SECRETS_WRITE",
    "description": "Treat writes to secret paths as high risk",
    "match": {
      "tool": "filesystem",
      "method": "/write|create|overwrite/i",
      "pathPattern": "/secrets/|/\\.env"
    },
    "score": 0.90,
    "priority": 10
  }
}

```

7. Built-in L1 Rules Reference

These rules always run. To suppress a rule, add its ID to `"mutedRules"`. To change its score, use `"ruleOverrides"`.

Filesystem & System

Rule ID	Triggered by	Score
L1_DELETE_FILE	delete_file, unlink, rm	0.90
L1_SENSITIVE_PATH_WRITE	Writes to .env, .ssh/, .aws/, credentials	0.90
L1_DROP_TABLE	drop, truncate on database tools	0.95
L1_DELETE_RECORD	delete, remove on non-filesystem tools	0.75
L1_EXECUTE_COMMAND	execute, exec, shell, spawn	0.80
L1_GIT_FORCE_PUSH	force, reset, rebase on git tools	0.85
L1_OVERWRITE_FILE	write_file, overwrite, create on filesystem	0.65
L1_READ_ONLY	read_*, list_*, get_*, describe_*	0.05
L1_SENSITIVE_FILE_TYPE	Writes to high-value file types (.pem, .key, .env, .crt) — likely key material	0.75

Slack

Rule ID	Triggered by	Score
L1_SLACK_SEND	send_message, post_message, reply on slack	0.70
L1_SLACK_DELETE	delete_message, delete, remove on slack	0.80
L1_SLACK_READ	list_*, get_*, read_*, search_*, history on slack	0.05

Gmail

Rule ID	Triggered by	Score
L1_GMAIL_SEND	send, reply, forward on gmail	0.90
L1_GMAIL_DRAFT	draft, create, compose (non-send) on gmail	0.30
L1_GMAIL_DELETE	delete, trash, remove on gmail	0.85
L1_GMAIL_READ	list_*, get_*, read_*, search_* on gmail	0.05

Google Calendar

Rule ID	Triggered by	Score
L1_GCAL_CREATE	create_event, insert, add on google-calendar	0.40
L1_GCAL_UPDATE	update_event, patch, modify on google-calendar	0.50
L1_GCAL_DELETE	delete_event, remove on google-calendar	0.70
L1_GCAL_READ	list_*, get_*, read_*, search_* on google-calendar	0.05

Database (SQLite / PostgreSQL / MySQL)

Rule ID	Triggered by	Score
L1_DB_DROP	DROP TABLE / DATABASE / INDEX	1.00
L1_DB_TRUNCATE	TRUNCATE — wipes a table with no row-level recovery	0.95
L1_DB_BATCH_DESTROY	Semicolon in a SQL parameter — possible multi-statement injection	0.95
L1_DB_DELETE_NO_WHERE	DELETE with no WHERE clause — removes every row	0.90
L1_DB_UPDATE_NO_WHERE	UPDATE with no WHERE clause — rewrites every row	0.85
L1_DB_DDL	CREATE / ALTER / PRAGMA — structural schema change	0.70
L1_DB_RESTORE	Snapshot restore — replaces current table contents	0.60
L1_DB_EXFIL	SELECT against sensitive table names (users, passwords, tokens, secrets, billing ...)	0.60
L1_DB_EXECUTE	INSERT / UPDATE / DELETE with a WHERE clause	0.30
L1_DB_READ	SELECT, list tables, describe — read-only	0.05

8. Adjusting Risk Thresholds

The three intervention zones are controlled by two thresholds in your policy file:

```
{
  "thresholds": {
    "allowBelow": 0.30,
    "blockAtOrAbove": 0.70
  }
}
```

Score range	Default action	Change to...
0.00 – 0.29	Allowed automatically	Raise allowBelow to be more strict
0.30 – 0.69	Paused — requires your approval	Narrow this band to reduce interruptions
0.70 – 1.00	Blocked outright	Lower blockAtOrAbove to block earlier

💡 Start with the defaults. After a few days in dry-run mode (`agentsgate start --dry-run`) you will see the actual score distribution for your agents and can tune from there.

9. Muting and Overriding Built-in Rules

Mute a rule (suppress false positives)

```
{
  "mutedRules": ["L1_OVERWRITE_FILE"]
}
```

Override a rule's score

```
{
  "ruleOverrides": {
    "L1_DELETE_FILE": 0.50,
    "L1_SLACK_SEND": 0.30
  }
}
```

The rule still fires and is logged — it just uses your score instead of the built-in one. Run `agentsgate policy list` to see all active rule IDs.

10. Quick Troubleshooting

Problem	Likely cause	Fix
Rule never fires (0 Hits)	match field is wrong	Use the Rule Tester in the dashboard Rules tab to test against a real operation
Too many approval prompts	threshold too low or broad rule	Raise allowBelow, or narrow the rule's match criteria
Legitimate op is blocked	L1 rule over-triggering	Add a custom rule with action: allow at priority 1, or mute the L1 rule
Rule fires on wrong operation	regex too broad	Tighten the regex or add more match fields
Changes not taking effect	policy.json not saved / wrong path	Check the path shown on the dashboard Rules tab header